

THIẾT KẾ HỆ THỐNG TƯỜNG LỬA ỨNG DỤNG WEB APPLICATION FIREWALL (WAF)

A. Giới thiệu

Hệ thống Quản lý Web Application Firewall (WAF) được xây dựng nhằm đáp ứng nhu cầu bảo vệ tập trung các ứng dụng web trước những mối đe dọa an ninh ngày càng gia tăng trong môi trường mạng phân tán. Hệ thống đóng vai trò là WAF tổng, thực hiện quản lý, điều phối và đồng bộ các WAF con được triển khai tại nhiều máy chủ, khu vực mạng hoặc vùng địa lý khác nhau, từ đó hình thành một lớp phòng thủ thống nhất và hiệu quả cho toàn bộ hạ tầng ứng dụng web.

Giải pháp cho phép giám sát, lọc và ngăn chặn các yêu cầu HTTP/HTTPS độc hại trước khi chúng tiếp cận các máy chủ web thật, giúp giảm thiểu nguy cơ bị khai thác lỗ hổng, tấn công từ chối dịch vụ hoặc đánh cắp dữ liệu. Thông qua cơ chế quản lý tập trung rule và log, hệ thống hỗ trợ phát hiện sớm các hành vi tấn công phổ biến như SQL Injection, Cross-Site Scripting (XSS), Command Injection, Path Traversal, dò quét lỗ hổng và các hình thức tấn công ứng dụng web khác.

Bên cạnh chức năng bảo vệ, hệ thống còn cung cấp khả năng giám sát, thống kê và phân tích log tập trung, giúp cán bộ quản trị có cái nhìn tổng thể về tình trạng an ninh của các ứng dụng web, từ đó đưa ra các biện pháp ứng phó kịp thời và hiệu quả, mà không cần truy cập thủ công vào từng máy chủ riêng lẻ.

B. Tính năng chính của giải pháp

1. Quản lý tập trung WAF phân tán

Quản lý, giám sát và cấu hình đồng thời nhiều WAF con trên các vùng mạng khác nhau thông qua một giao diện thống nhất.

2. Đồng bộ và quản lý rule bảo mật linh hoạt

Tạo, cập nhật, bật/tắt và phân phối rule bảo mật nhanh chóng từ WAF tổng xuống WAF con và từng ứng dụng cụ thể.

3. Bảo vệ toàn diện ứng dụng web

Phát hiện và ngăn chặn các hình thức tấn công web phổ biến như SQL Injection, XSS, LFI/RFI, Command Injection, dò quét và tấn công từ chối dịch vụ.

4. Thu thập và phân tích log tập trung

Thu thập log thời gian thực từ các WAF con, lưu trữ và phân tích tập trung bằng Elastic Stack, hỗ trợ truy vết và điều tra sự cố bảo mật.

5. Giám sát và cảnh báo an ninh

Phân tích hành vi bất thường, thống kê xu hướng tấn công và hỗ trợ cảnh báo kịp thời cho quản trị viên.

6. Phân quyền người dùng đa cấp

Hỗ trợ mô hình phân quyền Admin, WAF Manager và App Manager, đảm bảo kiểm soát truy cập chặt chẽ và phù hợp với tổ chức.

7. Khả năng mở rộng và tích hợp cao

Thiết kế theo kiến trúc microservice, dễ dàng mở rộng chức năng, tích hợp với các hệ thống giám sát, SIEM và nền tảng bảo mật khác.

8. Giao diện quản trị trực quan, dễ sử dụng

Giao diện web thân thiện, cung cấp dashboard tổng quan, thống kê và công cụ tìm kiếm log nhanh chóng, phục vụ hiệu quả công tác vận hành và giám sát.

C. Những ưu điểm khác biệt

1. Mô hình quản lý WAF hợp nhất, phù hợp triển khai quy mô lớn

- Thiết kế theo mô hình WAF tổng – WAF con, tách bạch rõ ràng giữa quản lý tập trung và bảo vệ cục bộ
- Phù hợp với hệ thống nhiều đơn vị, nhiều vùng mạng, yêu cầu thống nhất chính sách an toàn thông tin
- Giảm phụ thuộc vào cấu hình thủ công trên từng WAF riêng lẻ

2. Chuẩn hóa vận hành, giảm rủi ro do yếu tố con người

- Mọi thay đổi được thực hiện theo quy trình thống nhất, có kiểm soát
- Hạn chế lỗi cấu hình, chồng chéo chính sách khi vận hành nhiều WAF
- Nâng cao tính ổn định và khả năng duy trì hệ thống lâu dài

3. Chuyển từ phòng thủ bị động sang phòng thủ chủ động

- Không chỉ dừng ở việc ngăn chặn tấn công tức thời
- Hỗ trợ phân tích xu hướng, hành vi và mức độ rủi ro dựa trên dữ liệu thực tế
- Tạo cơ sở để cải tiến chính sách bảo vệ theo vòng đời ứng dụng web

4. Làm chủ công nghệ, không phụ thuộc nhà cung cấp

- Xây dựng trên nền tảng công nghệ mở, phổ biến và dễ kiểm soát
- Thuận lợi cho việc nghiên cứu, phát triển, tùy biến theo yêu cầu đặc thù
- Giảm chi phí dài hạn so với các giải pháp WAF thương mại đóng

5. Kiến trúc mở, sẵn sàng mở rộng và tích hợp

- Dễ dàng mở rộng khi quy mô ứng dụng hoặc lưu lượng tăng
- Thuận tiện tích hợp với các hệ thống giám sát, phân tích, SOC/SIEM
- Đáp ứng tốt yêu cầu phát triển trong dài hạn

6. Tăng cường kiểm soát, truy vết và minh bạch quản trị

- Mọi thao tác quản trị đều được ghi nhận và có khả năng truy vết
- Phù hợp với môi trường yêu cầu kỷ luật vận hành và kiểm soát nghiêm ngặt
- Hỗ trợ tốt cho công tác kiểm tra, đánh giá và giám sát an toàn thông tin

Hệ thống WAF tổng triển khai trên 1 máy chủ được cài đặt ảo hóa để tối ưu phần cứng. Tùy thuộc vào quy mô người dùng và dung lượng dữ liệu bản đồ để đưa ra cấu hình server phù hợp.

- Phân hệ frontend: Sử dụng ReactJS bao gồm các module:

+ Admin UI: Giao diện quản trị người dùng phục vụ công tác cấu hình tài khoản, danh mục quản lý, quản lý Waf con, quản lý đồng bộ rule, Quản lý đơn vị phụ trách.

+ Monitoring UI: giao diện người dùng phục vụ công tác xem log, tổng quan của WAF, quản lý ứng dụng cần bảo vệ.

- Phân hệ giao tiếp: sử dụng Resful API để giao tiếp giữa frontend và backend và Kafka để bắn socket thông điệp, đồng bộ rule, log.

+ Elasticsearch đóng vai trò lưu trữ và phân tích các log từ WAF con. Với khả năng xử lý thời gian thực, Elasticsearch giúp các nhà quản trị dễ dàng phát hiện các mối đe dọa và xu hướng tấn công, từ đó đưa ra các biện pháp phòng ngừa.

+ Kafka được sử dụng để quản lý và truyền tải luồng dữ liệu lớn giữa các thành phần. Nó nhận log từ các WAF con và chuyển tiếp đến hệ thống phân tích log trung tâm (Elasticsearch). Kafka cũng chịu trách nhiệm đồng bộ các thay đổi về quy tắc từ WAF tổng xuống các WAF con, bắn thông điệp khi xử lý các sự kiện.

+ Fleet Server quản lý các Elastic Agents, được cài đặt tại các WAF con để thu thập log từ WAF con và gửi về hệ thống trung tâm.

- Phân hệ backend:

+ Auth Service: Sử dụng google authen làm mã xác thực cấp 2.

+ Admin Service: Module quản lý các chức năng quản trị (Admin).

+ Log Service và Handel Log Servie: Module xử lý tách log và lưu vào CSDL.

+ Task Service: Module xử lý queue các request tới server và trả về phản hồi cho người dùng.

+ Handel Request và Handel Socket: Xử lý các yêu cầu người dùng và xử lý các thông điệp mà khi thực hiện 1 lệnh trên waf tổng đồng bộ xuống waf con và ngược lại. Kết quả sau khi thực hiện xong sẽ bắn qua Kafka về phía người dùng.

+ Rule Servie: Module quản lý đồng bộ rule sẽ gửi qua dạng file từ waf tổng xuống waf con và ngược lại đồng bộ những thay đổi của waf con tới waf tổng.

- Phân hệ Database:

+ MongoDB: giúp lưu trữ dữ liệu, cấu hình, lịch sử sự kiện, các nội dung quản lý chung và các tương tác về query dữ liệu.

+ File Storge: Lưu trữ log thô, các file cấu hình của Waf con đẩy lên.

+ Rule: Cơ sở dữ liệu tập luật được đồng bộ lên.

1. Mô hình triển khai hệ thống

a. Mô hình thông tin

Mô hình thông tin sẽ mô tả cách các luồng dữ liệu và thông tin được truyền giữa các thành phần chính, từ yêu cầu người dùng đến các WAF con để bảo vệ website, và đồng thời gửi log, thống kê về WAF tổng để quản lý và giám sát.

Mô tả chi tiết:

- **Người dùng (Client):** Gửi yêu cầu truy cập vào website qua mạng nội bộ.
- **DNS Server (nội bộ):** Phân giải tên miền của các ứng dụng web và trả tên miền trực tiếp đến các WAF con.
- **Router và Switch:** Điều phối luồng truy cập đến đúng WAF con phụ thuộc vào tên miền và đường dẫn, đảm bảo các kết nối mạng chính xác và tối ưu.
- **WAF Con (Reverse Proxy):**
 - + Bảo vệ các website cụ thể bằng cách kiểm tra và lọc các yêu cầu dựa trên các quy tắc bảo mật đã đồng bộ từ WAF tổng.
 - + Ghi nhận log và sự kiện bảo mật từ các yêu cầu truy cập và gửi về Kafka Cluster.
- **WAF Tổng:**
 - + Chịu trách nhiệm quản lý hệ thống WAF con, bao gồm việc đồng bộ hóa các quy tắc (rule) bảo mật, quản lý log từ các WAF con, theo dõi thống kê và quản lý người dùng.
 - + Thu thập log từ Kafka và cung cấp các giao diện xem báo cáo, thống kê, và các hoạt động giám sát tập trung.
- **Kafka Cluster:** Thu thập log và sự kiện từ các WAF con, đóng vai trò là trung tâm lưu trữ tạm thời cho log trước khi chuyển đến hệ thống giám sát.
- **Fleet Server:** Nhận log từ Kafka, chuẩn hóa và chuyển tiếp đến hệ thống giám sát Elastic Stack.
- **Hệ thống Giám sát và Phân tích (Elastic Stack):** Lưu trữ và phân tích log, cho phép đội ngũ bảo mật giám sát và phát hiện sự cố bảo mật qua các công cụ báo cáo và cảnh báo.

b. Mô hình triển khai

Trong mô hình triển khai ứng dụng bao gồm:

- **Các dịch vụ hệ thống bao gồm Switch, máy chủ ứng dụng Web.**
- WAF tổng cài đặt:

+ Kafka Cluster: Thu thập log từ các WAF con và lưu trữ tạm thời để Fleet Server truy xuất.

+ Fleet Server: Thu thập log từ Kafka, chuẩn hóa dữ liệu và chuyển tiếp đến hệ thống giám sát (Elastic Stack).

+ Elastic Stack: Hệ thống lưu trữ và phân tích log, cung cấp giao diện giám sát cho đội ngũ bảo mật, phát hiện và phản ứng với các sự cố bảo mật.

+ API server quản lý các Waf con và thống kê, xử lý các sự kiện điều khiển của người quản trị xuống cho waf con.

+ FE: Giao diện quản lý cho người quản trị viên waf tổng.

+ MongoDB: giúp lưu trữ dữ liệu, cấu hình, lịch sử sự kiện, các nội dung quản lý chung và các tương tác về query dữ liệu.

- WAF con cài đặt:

+ Elastisearch Agent: Elastic Agent là một công cụ thu thập dữ liệu cấu hình để gửi log và nhận lệnh, đồng bộ từ WAF tổng và bắn kết quả qua Kafka.

+ API server quản lý các App bảo vệ.

+ FE: Giao diện quản lý cho người quản trị viên waf con.

+ MongoDB: giúp lưu trữ dữ liệu, cấu hình, lịch sử sự kiện, các nội dung quản lý chung và các tương tác về query dữ liệu.

- **Các thiết bị mạng bao gồm Router, Switch, cáp mạng, đường truyền thông tin** sẽ thực hiện việc kết nối toàn mạng để truyền tải dữ liệu từ - đến các chủ và các máy trạm.

D. Thiết kế tính năng

STT	Tác nhân	Module	Tính năng	Mô tả Use Case
1	Admin	Quản lý vận hành	Tùy chỉnh cấu hình hệ thống	+ Thiết lập cấu hình hệ thống + Thay đổi cấu hình hệ thống + Áp dụng cấu hình hệ thống + Hoàn tác cấu hình hệ thống
2	Admin		Quản lý tài khoản xác thực và phân quyền người dùng	+ Thêm người dùng, tài khoản xác thực + Xóa người dùng, tài khoản xác thực + Điều chỉnh người dùng, tài khoản xác thực + Phân quyền người dùng, tài khoản xác thực + Kết thúc các phiên đăng nhập còn hiệu lực của người dùng
3	Admin		Cấu hình tham số của hệ thống	+ Thay đổi thời gian hệ thống + Thay đổi thời gian duy trì phiên kết nối + Giới hạn kết nối quản trị từ xa (theo IP, số phiên đồng thời)
4	Admin / WAF Manager		Quản trị log	+ Xem log + Xóa log + Xuất log + Tìm kiếm log theo từ khóa + Tùy chỉnh tham số log (thời gian lưu trữ, phân quyền, ...)
5	Hệ thống	Quản trị từ xa	Thiết lập kết nối mã hóa TLS	Thiết lập và duy trì kết nối quản trị từ xa thông qua giao thức mã hóa (TLS)
6	Hệ thống		Tự động hủy phiên quản trị	Tự động đăng xuất và hủy phiên quản trị từ xa khi hết thời gian duy trì phiên
7	Hệ thống	Quản lý xác thực và phân quyền	Xác thực bằng tài khoản – mật khẩu	+ Xác minh thông tin đăng nhập hệ thống mà người dùng cung cấp

				+ Lưu trữ thông tin đăng nhập an toàn
8	Admin		Cấu hình chính sách mật khẩu	Thiết lập độ phức tạp, độ dài, thời hạn mật khẩu
9	Admin		Phân nhóm tài khoản người dùng	Gán tài khoản vào nhóm quản trị viên hoặc người dùng thường
10	Hệ thống		Kiểm soát truy cập theo vai trò	Kiểm tra quyền trước khi cho phép truy cập chức năng
11	Admin / WAF Manager	Quản lý báo cáo	Thao tác với báo cáo	+ Tạo báo cáo mới + Xem báo cáo + Xóa báo cáo + Tạo báo cáo theo mẫu + Tải báo cáo
12	Admin / WAF Manager		Tinh chỉnh nội dung báo cáo	+ Định nghĩa mẫu báo cáo + Áp dụng quy tắc tìm kiếm, lọc log để bổ sung hoặc chỉnh sửa nội dung báo cáo + Chọn định dạng xuất báo cáo (WORD, EXCEL, PDF, HTML, XML)
13	Admin	Quản lý tập luật	Thêm luật mới	Tạo mới một luật bảo vệ và đưa vào tập luật của hệ thống
14	Admin		Tinh chỉnh luật	+ Chỉnh sửa nội dung, điều kiện, tham số của luật bảo vệ + Áp dụng và điều chỉnh tập luật theo từng ứng dụng Web cụ thể
15	Admin		Xóa luật	Xóa luật không còn sử dụng hoặc không hợp lệ
16	Admin		Nhập tập luật bằng tệp tin	Nhập tập luật vào hệ thống bằng tệp tin
17	Admin		Kích hoạt/vô hiệu hóa tập luật	Bật hoặc tắt hiệu lực của luật bảo vệ

18	Admin / WAF Manager		Tìm kiếm tập luật	Tìm kiếm luật theo tên, loại tấn công, trạng thái
19	Admin / WAF Manager		Xuất tập luật ra tệp tin	Xuất tập luật hoặc luật được chọn ra tệp tin
20	Hệ thống		Thông báo bản cập nhật luật mới	+ Hệ thống tự động phát hiện và thông báo cho quản trị viên khi có bản cập nhật tập luật bảo vệ mới + Kiểm tra tính hợp lệ và trạng thái áp dụng của bản cập nhật luật
21	Admin		Tải và áp dụng bản cập nhật luật	+ Quản trị viên tải trực tuyến bản cập nhật tập luật bảo vệ từ nguồn cung cấp + Quản trị viên chủ động áp dụng bản cập nhật tập luật đã tải
22	Admin / WAF Manager	Quản lý vòng đời chính sách	Quản lý phiên bản chính sách	Tạo, lưu trữ và quản lý các phiên bản chính sách bảo vệ (rule, cấu hình)
23	Admin		Phê duyệt và phát hành chính sách	Thực hiện quy trình phê duyệt (4-eyes) trước khi áp dụng chính sách
24	Admin / WAF Manager		Triển khai và hoàn tác chính sách	Áp dụng chính sách đã phê duyệt hoặc hoàn tác về phiên bản trước đó
25	Admin / SOC Analyst		Giám sát & audit vòng đời	Theo dõi lịch sử thay đổi, áp dụng, hoàn tác chính sách
26	Hệ thống	Ghi log	Log quản trị hệ thống	+ Ghi log đăng nhập/đăng xuất

				+ Ghi log xác thực trước truy cập tài nguyên, sử dụng chức năng HT + Ghi log áp dụng/hoàn tác cấu hình + Ghi log khởi động lại/tắt hệ thống + Ghi log thay đổi thủ công thời gian hệ thống
27	Hệ thống		Thông tin Log quản trị	+ Ghi nhận đầy đủ thời điểm phát sinh log (năm, tháng, ngày, giờ, phút, giây) + Ghi nhận địa chỉ IP hoặc định danh máy trạm phát sinh hành vi quản trị + Ghi nhận thông tin tác nhân thực hiện hành vi (tài khoản, hệ thống, dịch vụ) + Ghi nhận loại hành vi quản trị (đăng nhập, đăng xuất, thêm, sửa, xóa, cập nhật, hoàn tác...) + Ghi nhận kết quả hành vi (thành công hoặc thất bại) + Ghi nhận nguyên nhân khi hành vi không thành công (không đủ quyền, không tồn tại tài nguyên...)
28	Hệ thống		Log bảo vệ ứng dụng Web	+ Ghi nhận sự kiện truy cập vào tài nguyên của ứng dụng web được bảo vệ + Ghi nhận sự kiện cảnh báo phát sinh khi thực thi luật bảo vệ + Ghi nhận sự kiện cảnh báo phát sinh khi thực thi luật bảo vệ + Ghi nhận IP hoặc định danh máy nguồn gửi request + Ghi nhận IP hoặc định danh máy đích (WAF/ứng dụng)

				+ Ghi nhận giao thức truy cập (HTTP/HTTPS) + Ghi nhận đường dẫn URL và danh sách tham số + Ghi nhận phương thức truy vấn (GET, POST, HEAD, ...) + Ghi nhận mã trạng thái HTTP (200, 403, 404, ...) + Ghi nhận hành động của luật (chặn, hủy kết nối, điều hướng, cho phép, ...) + Ghi nhận lý do/giải trình cho hành động của luật bảo vệ
29			Định danh Log	Cho phép chuẩn hóa log theo định dạng đã được định nghĩa trước để truyền dữ liệu cho các phần mềm quản lý, phân tích, điều tra log
30	Hệ thống		Tích hợp hệ thống	Xuất log để tích hợp vào SIEM hoặc hệ thống phân tích/điều tra khác
31	Hệ thống	Hiệu năng	Xử lý với giao thức HTTP	+ Hệ thống xử lý trung bình đến 30.000 kết nối HTTP/giây trong điều kiện vận hành bình thường + Hệ thống duy trì tối đa 20.000 phiên HTTP đồng thời + Đảm bảo độ trễ trung bình khi gửi yêu cầu $HTTP \leq 3 \text{ ms}$
32	Hệ thống		Xử lý với giao thức HTTPS	+ Hệ thống xử lý trung bình đến 20.000 kết nối TLS,SSL/giây trong điều kiện vận hành bình thường + Hệ thống duy trì tối đa 14.000 phiên TLS,SSL đồng thời

				+ Đảm bảo độ trễ trung bình Gửi yêu cầu ≤ 5 ms
33	Hệ thống	Chức năng tự bảo vệ tầng ứng dụng	Ngăn chặn SQL Injection	Phân tích request và phát hiện, ngăn chặn các mẫu tấn công SQL Injection
34	Hệ thống		Ngăn chặn OS Command Injection	Phát hiện và ngăn chặn các payload thực thi lệnh hệ điều hành
35	Hệ thống		Ngăn chặn XPath Injection	Phát hiện các payload tấn công XPath Injection trong request
36	Hệ thống		Ngăn chặn Remote File Inclusion (RFI)	Phát hiện và ngăn chặn việc tải/nhúng tệp từ nguồn bên ngoài
37	Hệ thống		Ngăn chặn Local File Inclusion (LFI)	Phát hiện và ngăn chặn truy cập trái phép tệp cục bộ
38	Hệ thống		Ngăn chặn Cross-Site Scripting (XSS)	Phát hiện và ngăn chặn mã độc script phía client
39	Hệ thống		Ngăn chặn Cross-Site Request Forgery (CSRF)	Phát hiện hành vi giả mạo yêu cầu từ phía người dùng
40	Hệ thống	Bảo vệ ứng dụng Web	Phát hiện & chặn SQL Injection	Phân tích request gửi tới ứng dụng Web, phát hiện và ngăn chặn tấn công SQL Injection
41	Hệ thống		Phát hiện & chặn OS Command Injection	Phát hiện payload thực thi lệnh hệ điều hành trong request tới ứng dụng Web
42	Hệ thống		Phát hiện & chặn XPath Injection	Phát hiện tấn công XPath Injection nhắm vào ứng dụng Web
43	Hệ thống		Phát hiện & chặn Brute-force	Phát hiện hành vi brute-force (đăng nhập/thử mật khẩu liên tục)
44	Hệ thống		Phát hiện & chặn RFI	Phát hiện và ngăn chặn tấn công Remote File Inclusion vào ứng dụng Web

45	Hệ thống		Phát hiện & chặn LFI	Phát hiện và ngăn chặn tấn công Local File Inclusion vào ứng dụng Web
46	Hệ thống		Phát hiện & chặn XSS	Phát hiện và ngăn chặn mã độc Cross-Site Scripting
47	Hệ thống		Phát hiện & chặn CSRF	Phát hiện và ngăn chặn tấn công Cross-Site Request Forgery
48	Admin / WAF Manager	Bảo vệ API	Quản lý & định danh API	Khai báo, nhận diện và đưa các API endpoint (path, method, version) vào phạm vi bảo vệ
49	Hệ thống		Xác thực & kiểm soát truy cập API	Xác thực API key/JWT/OAuth token, kiểm soát quyền truy cập theo claim/role → Truy cập hợp lệ hoặc bị từ chối
50	Hệ thống		Rate limiting & chống API abuse	Giới hạn truy cập API theo token/client/IP, phát hiện hành vi lạm dụng
51	Hệ thống		Schema validation	Kiểm tra request/response theo OpenAPI/Swagger, phát hiện tham số bất thường → Request sai schema bị chặn
52	Hệ thống		Phát hiện BOLA	Phát hiện truy cập trái phép tài nguyên API theo Object ID
53	Hệ thống		Phát hiện rò rỉ dữ liệu API	Phát hiện excessive data exposure trong response API
54	Hệ thống		Phát hiện tấn công logic API	Phát hiện sai lệch luồng nghiệp vụ, hành vi bất thường khi gọi API
55	Admin / SOC Analyst		Giám sát & tích hợp log API	Gán risk score cho API/token/client và áp dụng biện pháp xử lý phù hợp
56	Hệ thống	Triển khai cơ chế bảo vệ	Phát hiện theo tập luật	Phát hiện và ngăn chặn tấn công dựa trên phân tích tập luật bảo vệ

57	Hệ thống		Phát hiện theo hành vi	Phát hiện và ngăn chặn tấn công dựa trên hành vi truy cập bất thường
58	Hệ thống		Phát hiện nội dung độc hại URL	Phát hiện và xử lý nội dung độc hại trong URL của request
59	Hệ thống		Che giấu thông tin hệ thống	Che giấu thông tin về HĐH, nền tảng, kiến trúc web của ứng dụng
60	Admin / WAF Manager	Virtual Patching	Quản lý lỗ hổng ứng dụng	Khai báo, quản lý danh sách lỗ hổng (CVE) liên quan đến ứng dụng web được bảo vệ
61	Hệ thống		Ánh xạ rule ↔ CVE	Liên kết các rule bảo vệ với mã CVE tương ứng
62	Hệ thống		Triển khai vá ảo	Áp dụng rule như một biện pháp vá tạm thời để ngăn chặn khai thác lỗ hổng
63	Admin / WAF Manager		Kích hoạt/vô hiệu vá ảo	Bật hoặc tắt cơ chế vá ảo theo từng CVE hoặc ứng dụng
64	Hệ thống		Đánh giá rủi ro theo CVSS	Đánh giá mức độ rủi ro dựa trên điểm CVSS của CVE
65	Admin / SOC Analyst		Giám sát & báo cáo vá ảo	Theo dõi trạng thái vá ảo, mức độ rủi ro và sự kiện liên quan
66	Admin	Thiết lập cấu hình giao thức	Cấu hình mã hóa/giải mã	Thiết lập phương pháp mã hóa và giải mã ký tự
67	Admin		Cấu hình tham số giao thức	Thiết lập giới hạn kích thước gói yêu cầu/phản hồi và độ dài tiêu đề
68	Hệ thống	Cảnh báo tấn công	Gửi cảnh báo đa kênh	Tự động gửi cảnh báo tấn công qua SMS, email, Telegram
69	Hệ thống	Threat Intelligence	Tích hợp nguồn Threat Intelligence	Kết nối và tiếp nhận dữ liệu Threat Intelligence từ các nguồn bên ngoài (IP reputation, blacklist, feed công cộng/đối tác)

70	Hệ thống		Quản lý danh tiếng IP	Đánh giá và phân loại mức độ tin cậy của địa chỉ IP dựa trên Threat Intelligence
71	Hệ thống		Phát hiện nguồn tấn công nguy hiểm	Phát hiện truy cập từ các nguồn độc hại (TOR, Proxy, Botnet, C2)
72	Hệ thống		Ảnh xạ TI với sự kiện tấn công	Liên kết thông tin Threat Intelligence với các sự kiện tấn công phát hiện bởi WAF
73	Hệ thống		Hỗ trợ chấm điểm rủi ro	Cung cấp dữ liệu TI cho Risk Engine để nâng cao độ chính xác chấm điểm rủi ro
74	Admin / SOC Analyst		Giám sát & quản lý TI	Theo dõi trạng thái feed, nguồn TI, lịch sử cập nhật và tác động tới hệ thống
75	Hệ thống	Phát hiện tấn công dựa trên AI	Phát hiện zero-day	Phát hiện các tấn công zero-day
76	Hệ thống		Phát hiện Botnet	Phát hiện lưu lượng từ botnet
77	Hệ thống		Phát hiện payload độc hại	Phát hiện tấn công sử dụng malicious payload
78	Hệ thống	Hỗ trợ giao thức TLS/SSL	Hỗ trợ kết nối HTTPS	Xử lý các giao dịch HTTPS giữa client và ứng dụng web thông qua cơ chế mã hóa TLS/SSL
79	Admin / WAF Manager		Cấu hình phiên bản TLS/SSL	Cho phép cấu hình và sử dụng các phiên bản giao thức TLS/SSL được hỗ trợ
80	Hệ thống		Ghi log sự kiện TLS	Ghi nhận thông tin phiên TLS/SSL (phiên bản, trạng thái kết nối, lỗi nếu có)
81	Hệ thống	Cân bằng tải	Phân phối lưu lượng	Phân phối lưu lượng truy cập đến các máy chủ backend
82	Hệ thống	Quản lý và đánh giá rủi ro	Chấm điểm rủi ro đa chiều	Đánh giá rủi ro dựa trên nhiều yếu tố như IP, ứng dụng, người dùng, hành vi và lịch sử tấn công
83	Hệ thống		Phân loại mức độ rủi ro	Phân loại rủi ro theo các mức (Thấp / Trung bình / Cao / Nghiêm trọng)

84	Hệ thống		Ưu tiên sự kiện tấn công	Sắp xếp và ưu tiên các sự kiện/cảnh báo theo mức độ rủi ro
85	Hệ thống		Phản ứng theo mức rủi ro	Áp dụng biện pháp xử lý tương ứng (block, rate-limit, challenge) khi vượt ngưỡng
86	Admin / SOC Analyst		Giám sát & theo dõi rủi ro	Hiển thị tổng quan, xu hướng rủi ro theo thời gian
87	Admin		Cấu hình chính sách chấm điểm	Thiết lập trọng số, ngưỡng và quy tắc chấm điểm rủi ro
88	Admin/WAF Manager	Quản lý hệ thống	Theo dõi tổng quan	Xem dashboard thống kê toàn hệ thống